

Notatka Służbowa

DO: Zarząd FinTrust Bank S.A.

OD: Audytor Wewnętrzny

DATA: 25 lutego 2026

TEMAT: Wymogi regulacyjne przed podłączeniem do sieci SWIFT

Wprowadzenie

Podłączenie banku do sieci SWIFT wiąże się z szeregiem wymogów prawnych i standardów bezpieczeństwa. Niespełnienie tych regulacji może skutkować utratą licencji bankowej, karami finansowymi lub wykluczeniem z systemu płatności międzynarodowych.

I. Nadzór Krajowy (KNF i Rekomendacja D)

Rekomendacja D to zbiór najlepszych praktyk w zakresie zarządzania obszarami technologii informacyjnej i bezpieczeństwa środowiska teleinformatycznego w bankach, wydany przez KNF.

Kluczowe wymogi dla działu IT/Security:

- Zarządzanie tożsamością:** Konieczne wdrożenie zasady minimalnych uprawnień. Każdy użytkownik otrzymuje dostęp tylko do zasobów niezbędnych do wykonywania obowiązków.
- Separacja uprawnień:** Funkcje krytyczne muszą być rozdzielone między różne osoby (zasada "four eyes"). Przykład: osoba inicjująca przelew nie może go sama zatwierdzić.
- Środowiska:** Obligatoryjne oddzielenie środowisk deweloperskiego, testowego i produkcyjnego. Dane produkcyjne nie mogą być używane w środowiskach niższych bez anonimizacji.
- Model 3 Lines of Defense:** Bank musi wdrożyć trzy linie obrony (zarządzanie operacyjne, zarządzanie ryzykiem i compliance, audyt wewnętrzny).

II. Odporność Operacyjna (DORA)

DORA (Digital Operational Resilience Act) obowiązuje od stycznia 2025 roku we wszystkich krajach UE i nakłada na instytucje finansowe wymogi dotyczące odporności cyfrowej.

Obowiązki w zakresie incydentów ICT:

- Zgłaszanie poważnych incydentów do KNF w ciągu 4 godzin od wykrycia (raport wstępny).
- Raport pośredni w ciągu 72 godzin.
- Raport końcowy z analizą przyczyn źródłowych i działaniami naprawczymi.

Zarządzanie ryzykiem dostawców zewnętrznych (Third Party Risk):

- Bank musi prowadzić rejestr wszystkich krytycznych dostawców ICT (np. AWS, Azure).
 - Umowy z dostawcami chmury muszą zawierać klauzule o prawie do audytu i dostępie do danych przez organy nadzoru.
 - Obowiązkowe testy odporności operacyjnej (TLPT - Threat-Led Penetration Testing) co 3 lata.
 - KNF może zażądać wglądu w infrastrukturę dostawcy chmurowego.
-

III. Standardy Międzynarodowe (SWIFT CSP)

SWIFT Customer Security Programme (CSP) wymaga od wszystkich użytkowników sieci SWIFT przestrzegania **Customer Security Controls Framework (CSCF)**.

CSCF to zbiór 31 obligacyjnych i zalecanych kontroli bezpieczeństwa, podzielonych na kategorie:

- Bezpieczeństwo środowiska lokalnego
- Segmentacja sieci
- Redukcja powierzchni ataku
- Wykrywanie anomalii

Certyfikacja:

Bank **nie może** sam sobie wystawić certyfikatu. Wymagany jest:

- Coroczny self-assessment przesyłany do SWIFT
- Niezależny audyt zewnętrzny potwierdzający zgodność z CSCF
- Atestacja przez kierownictwo wyższego szczebla

Kluczowy wymóg techniczny - segmentacja sieci:

Środowisko SWIFT musi być oddzielone od reszty sieci bankowej za pomocą firewalli. Dostęp tylko dla upoważnionych systemów i użytkowników z wdrożonym **MFA (Multi-Factor Authentication)** dla wszystkich kont administratorów.

IV. Płatności i Użytkownicy (PSD2/PSD3)

SCA (Strong Customer Authentication):

SCA to wymóg uwierzytelniania użytkownika za pomocą co najmniej dwóch z trzech czynników:

- Wiedza (hasło, PIN)
- Posiadanie (telefon, token)
- Cechy biometryczne (odcisk palca, rozpoznawanie twarzy)

Logowanie samym hasłem jest **niedozwolone** dla operacji płatniczych i dostępu do wrażliwych danych. SCA chroni przed przejęciem konta i nieautoryzowanymi transakcjami.

Open Banking API:

- Wszystkie API muszą wykorzystywać **OAuth 2.0** lub równoważny standard autoryzacji.
 - Komunikacja wyłącznie przez szyfrowane kanały (TLS 1.2+).
 - Obowiązkowe testy penetracyjne API przed uruchomieniem i co najmniej raz w roku.
 - Rejestr autoryzowanych dostawców TPP (Third Party Providers) zgodny z listą EBA.
-

V. Przeciwdziałanie Praniu Brudnych Pieniędzy (AML)

Dlaczego AML to wymóg bezpieczeństwa?

Systemy AML nie tylko chronią integralność finansową, ale również:

- Zapobiegają wykorzystaniu banku do finansowania terroryzmu
- Chronią infrastrukturę przed cyberprzestępcami (grupy przestępcze często wykorzystują słabe kontrole AML)
- Są częścią zarządzania ryzykiem operacyjnym (zgodnie z DORA)

Sankcje za naruszenia:

- Kary finansowe do 10% rocznych obrotów banku (ustawa AML)
- Cofnięcie licencji bankowej przez KNF
- Wykluczenie z sieci SWIFT w przypadku przepuszczenia transakcji do krajów objętych embargiem międzynarodowym (np. sankcje ONZ, UE, USA)
- Odpowiedzialność karna członków Zarządu

Status Operatora Usługi Kluczowej:

FinTrust Bank S.A., jako podmiot świadczący usługi płatnicze, jest prawdopodobnie **Operatorem Usługi Kluczowej** zgodnie z ustawą o Krajowym Systemie Cyberbezpieczeństwa. Oznacza to dodatkowe obowiązki:

- Zgłaszanie incydentów do CSIRT NASK
 - Wdrożenie procedur zarządzania incydentami
 - Kontrole ze strony organów państwowych
-

Rekomendacje

1. Powołanie Komitetu Zgodności SWIFT z udziałem CISO, CTO i Head of Compliance
 2. Budżet na zewnętrzny audyt SWIFT CSP (kwartał III 2026)
 3. Aktualizacja polityk bezpieczeństwa zgodnie z DORA do 30.06.2026
 4. Szkolenia dla pracowników z zakresu tajemnicy bankowej i AML
-

Audyt Wewnętrzny

FinTrust Bank S.A.